



UNIVERSIDADE REGIONAL DO NOROESTE DO
ESTADO DO RIO GRANDE DO SUL
CURSO DE CIÊNCIA DA COMPUTAÇÃO

CRISTIAN DOS SANTOS SIQUEIRA, DANIEL HENNIG, MARCO ANTÔNIO HENDGES,
WILLIAM RAFAEL FAGUNDES, PEDRO FROSI

GOVERNANÇA, SEGURANÇA E PROTEÇÃO DE DADOS EM
PROCESSAMENTO DE LOGS DE INFRAESTRUTURA DE
TECNOLOGIA DA INFORMAÇÃO

Santa Rosa/RS

2026

CRISTIAN DOS SANTOS SIQUEIRA, DANIEL HENNIG, MARCO ANTÔNIO HENDGES,
WILLIAM RAFAEL FAGUNDES, PEDRO FROSI

GOVERNANÇA, SEGURANÇA E PROTEÇÃO DE DADOS EM
PROCESSAMENTO DE LOGS DE INFRAESTRUTURA DE
TECNOLOGIA DA INFORMAÇÃO

Trabalho de Projeto Integrador apresentado ao curso de Ciência da Computação da Universidade Regional do Noroeste do Estado do Rio Grande do Sul – UNIJUÍ, como requisito parcial para aprovação na disciplina de Segurança de Dados.

Orientador(a): Prof. Marcos Sulzbach
Morgenstern

Santa Rosa/RS

2026

AGRADECIMENTOS

Agradecemos ao Prof. Marcos Sulzbach Morgenstern pela orientação e pelo espaço de aprendizado proporcionado ao longo da disciplina. À UNIJUÍ, pelo suporte institucional. Aos colegas de curso que contribuíram com discussões e revisões ao longo do desenvolvimento deste projeto.

RESUMO

Os logs de infraestrutura de tecnologia da informação – gerados por roteadores, servidores, firewalls e sistemas correlatos – contêm dados capazes de identificar pessoas naturais de forma direta ou indireta, sujeitando seu tratamento às disposições da Lei Geral de Proteção de Dados Pessoais (LGPD – Lei nº 13.709/2018), do Regulamento Geral de Proteção de Dados europeu (GDPR) e das normativas da Autoridade Nacional de Proteção de Dados (ANPD), em especial a Resolução CD/ANPD nº 19/2024. Este trabalho desenvolve uma proposta estruturada de governança e proteção de dados aplicada a logs de infraestrutura de TI, contemplando: a identificação e classificação dos dados pessoais presentes nesses registros; a fundamentação legal e normativa aplicável; políticas de segurança da informação para uso, acesso, retenção e descarte de logs; diretrizes de anonimização, pseudonimização e sanitização, com demonstração prática por meio do framework Microsoft Presidio aplicado a logs MikroTik RouterOS; um plano de contingência e resposta a incidentes; e uma análise crítica de conformidade e dos impactos éticos, sociais e institucionais do uso de dados de logs. O conjunto das propostas visa apoiar organizações na tomada de decisão em segurança da informação e no cumprimento das obrigações legais vigentes.

Palavras-chave: lgpd; governança de dados; logs de infraestrutura; anonimização; segurança da informação; microsoft presidio; anpd; gdpr.

LISTA DE QUADROS

Quadro 1 – Dados de identificação de rede em logs e enquadramento na LGPD	14
Quadro 2 – Ciclo de vida do dado em logs de infraestrutura	16
Quadro 3 – Princípios da LGPD e implicações para logs de infraestrutura	18
Quadro 4 – Categorias de log, base legal e finalidade da coleta	21
Quadro 5 – Perfis de acesso RBAC para logs de infraestrutura	22
Quadro 6 – Prazos de retenção propostos por categoria de log	22
Quadro 7 – Técnicas de anonimização recomendadas por tipo de dado em logs	25
Quadro 8 – Pipeline de processamento do MikroTik Log Anonymizer	25
Quadro 9 – Classificação de incidentes envolvendo logs de infraestrutura	33

LISTA DE TABELAS

Tabela 1 – Análise de conformidade com a LGPD	37
Tabela 2 – Comparativo LGPD × GDPR para tratamento de logs de infraestrutura . . .	38

LISTA DE ABREVIATURAS E SIGLAS

ABNT	Associação Brasileira de Normas Técnicas
ANPD	Autoridade Nacional de Proteção de Dados
GDPR	General Data Protection Regulation
IP	Internet Protocol
ISP	Internet Service Provider
LGPD	Lei Geral de Proteção de Dados Pessoais
MAC	Media Access Control
NLP	Natural Language Processing
PII	Personally Identifiable Information
RIPD	Relatório de Impacto à Proteção de Dados
SGSI	Sistema de Gestão de Segurança da Informação
SIEM	Security Information and Event Management
SOC	Security Operations Center
SSH	Secure Shell
TI	Tecnologia da Informação
UNIJUÍ	Universidade Regional do Noroeste do Estado do Rio Grande do Sul

SUMÁRIO

1	INTRODUÇÃO	10
1.1	JUSTIFICATIVA	10
1.2	OBJETIVOS	11
1.2.1	Objetivo Geral	11
1.2.2	Objetivos Específicos	11
1.3	DELIMITAÇÃO DO ESCOPO	12
1.4	ESTRUTURA DO TRABALHO	12
2	NATUREZA DOS DADOS EM LOGS DE INFRAESTRUTURA DE TI	13
2.1	O QUE SÃO LOGS DE INFRAESTRUTURA	13
2.2	CLASSIFICAÇÃO DOS DADOS PRESENTES EM LOGS	13
2.2.1	Dados de Identificação de Rede	14
2.2.2	Dados de Autenticação e Acesso	14
2.2.3	Dados de Comportamento e Tráfego	14
2.2.4	Dados de Configuração e Administração	15
2.3	O RISCO DE REIDENTIFICAÇÃO POR COMBINAÇÃO	15
2.4	CICLO DE VIDA DO DADO NO LOG	15
3	FUNDAMENTAÇÃO LEGAL E NORMATIVA	17
3.1	LEI GERAL DE PROTEÇÃO DE DADOS PESSOAIS	17
3.1.1	Princípios Fundamentais Aplicáveis a Logs	17
3.1.2	Bases Legais para Tratamento de Logs	17
3.1.3	Anonimização e seus Efeitos Legais	18
3.1.4	Obrigações do Controlador quanto à Segurança	18
3.2	REGULAMENTO GERAL DE PROTEÇÃO DE DADOS (GDPR)	18
3.2.1	Conceitos do GDPR Aplicáveis a Logs	19
3.3	NORMATIVAS DA ANPD	19
3.3.1	Resolução CD/ANPD nº 19/2024	19
3.3.2	Guia de Anonimização e Pseudonimização da ANPD	20
3.4	MARCO CIVIL DA INTERNET	20
4	POLÍTICAS DE SEGURANÇA DA INFORMAÇÃO	21
4.1	POLÍTICA DE CLASSIFICAÇÃO E COLETA	21
4.2	POLÍTICA DE CONTROLE DE ACESSO	21
4.3	POLÍTICA DE RETENÇÃO	22
4.4	POLÍTICA DE DESCARTE SEGURO	23

4.5	POLÍTICA DE COMPARTILHAMENTO	23
4.6	DOCUMENTAÇÃO DAS ATIVIDADES DE TRATAMENTO	23
5	DIRETRIZES DE ANONIMIZAÇÃO, PSEUDONIMIZAÇÃO E SANITIZAÇÃO	24
5.1	CONCEITOS E DISTINÇÕES	24
5.2	TÉCNICAS RECOMENDADAS POR TIPO DE DADO	24
5.3	ARQUITETURA DA FERRAMENTA DEMONSTRATIVA	24
5.4	MOTOR DE ANONIMIZAÇÃO (CORE_ANONYMIZER.PY)	26
5.5	RECOGNIZERS DO PRESIDIO: IP NATIVO E MAC CUSTOMIZADO . .	28
5.6	OPERADORES DE ANONIMIZAÇÃO	28
5.7	PSEUDONIMIZAÇÃO POR HASH COM SALT	30
5.8	GENERALIZAÇÃO TEMPORAL	30
5.9	INTERFACE WEB (APP.PY)	31
5.10	RESULTADOS DA VALIDAÇÃO	31
5.11	DIRETRIZES PARA APLICAÇÃO	32
6	PLANO DE CONTINGÊNCIA E RESPOSTA A INCIDENTES	33
6.1	FUNDAMENTAÇÃO E OBJETIVOS DO PLANO	33
6.2	CLASSIFICAÇÃO DE INCIDENTES	33
6.3	FASES DO PLANO DE RESPOSTA	34
6.3.1	Fase 1 — Preparação	34
6.3.2	Fase 2 — Identificação	34
6.3.3	Fase 3 — Contenção	34
6.3.4	Fase 4 — Investigação e Erradicação	35
6.3.5	Fase 5 — Notificação	35
6.3.6	Fase 6 — Recuperação e Lições Aprendidas	35
6.4	BACKUPS E CONTINUIDADE	36
7	ANÁLISE DE CONFORMIDADE	37
7.1	CONFORMIDADE COM A LGPD	37
7.2	CONFORMIDADE COM O GDPR	37
7.3	CONFORMIDADE COM A RESOLUÇÃO CD/ANPD N° 19/2024	38
7.4	LACUNAS E RECOMENDAÇÕES ADICIONAIS	38
8	REFLEXÃO ÉTICA, SOCIAL E INSTITUCIONAL	40
8.1	O LOG COMO INSTRUMENTO DE VIGILÂNCIA	40
8.2	ASSIMETRIA DE PODER E CONSENTIMENTO	40
8.3	RISCOS SOCIAIS DO USO INADEQUADO DE LOGS	41
8.4	RESPONSABILIDADE INSTITUCIONAL	41
8.5	O PAPEL DO PROFISSIONAL DE COMPUTAÇÃO	42

8.6	CONTRIBUIÇÃO DO PROJETO PARA A SOCIEDADE	42
9	CONSIDERAÇÕES FINAIS	43
9.1	SÍNTESE DAS CONTRIBUIÇÕES	43
9.2	CONCLUSÕES	44
9.3	TRABALHOS FUTUROS	44
	REFERÊNCIAS	46
	APÊNDICE A – CÓDIGO DEMONSTRATIVO DE ANONIMIZAÇÃO DE LOGS	47

1 INTRODUÇÃO

A infraestrutura de tecnologia da informação das organizações modernas – composta por roteadores, servidores, firewalls, sistemas de detecção de intrusão e demais dispositivos de rede – produz continuamente registros operacionais denominados *logs*. Esses arquivos documentam eventos como conexões de rede, autenticações, transferências de dados, falhas de sistema e tentativas de acesso não autorizado. Longe de serem meros registros técnicos, os logs contêm informações que, isoladamente ou em combinação, são capazes de identificar pessoas naturais de forma direta ou indireta – configurando, portanto, dados pessoais nos termos do art. 5º, inciso I, da Lei Geral de Proteção de Dados Pessoais (LGPD – Lei nº 13.709/2018) (Brasil, 2018).

Essa realidade impõe às organizações responsabilidades que vão além da gestão técnica da infraestrutura. O tratamento inadequado de logs – seja pelo armazenamento indiscriminado, pelo compartilhamento sem controles ou pela ausência de políticas de retenção e descarte – pode gerar riscos legais, éticos e institucionais significativos. No Brasil, a ANPD já sinalizou, por meio de sua Resolução CD/ANPD nº 19/2024, a crescente atenção regulatória sobre práticas de tratamento de dados em ambientes corporativos (Autoridade Nacional de Proteção de Dados (ANPD), 2024). No cenário internacional, o Regulamento Geral de Proteção de Dados europeu (GDPR) consolidou um conjunto de obrigações que serve de referência para a interpretação e aplicação da legislação brasileira (European Parliament, 2016).

Diante desse contexto, o presente projeto propõe-se a responder ao seguinte problema norteador: *Como estruturar e documentar políticas, regras e diretrizes para o uso, anonimização, sanitização, retenção, processamento e compartilhamento de dados de logs de infraestrutura de TI, de modo a apoiar a tomada de decisão em segurança da informação, garantir conformidade com a legislação brasileira de proteção de dados e normas internacionais, e subsidiar políticas de segurança e planos de contingência para resposta a incidentes?*

Para responder a essa questão, o projeto desenvolve uma proposta estruturada de governança e proteção de dados aplicada a logs de infraestrutura, com apoio pontual de código para demonstração das técnicas de anonimização e sanitização propostas. O objeto de estudo concreto são os logs gerados por roteadores MikroTik RouterOS, amplamente utilizados por provedores de acesso à internet (ISPs) e redes corporativas brasileiras, cuja densidade de dados pessoais os torna um caso particularmente relevante para a análise.

1.1 JUSTIFICATIVA

A ausência de políticas formais de governança para logs de TI é um problema recorrente em organizações de todos os portes. Administradores de rede frequentemente armazenam logs brutos por períodos indefinidos, sem critérios de acesso, sem procedimentos de descarte e sem

qualquer processo de anonimização – expondo dados de usuários, clientes e colaboradores a riscos desnecessários.

Do ponto de vista legal, a LGPD não contempla exceção para dados presentes em logs técnicos: se a informação permite identificar uma pessoa natural, ela é dado pessoal e seu tratamento deve observar os princípios e obrigações da lei. Do ponto de vista ético, a acumulação irrestrita de logs representa uma forma de vigilância implícita sobre os usuários da rede, sem que estes tenham conhecimento ou consentimento. Do ponto de vista institucional, uma violação de dados envolvendo logs pode resultar em sanções administrativas, danos reputacionais e responsabilização civil e penal dos gestores.

Este trabalho justifica-se, portanto, pela necessidade concreta de estruturar um conjunto de diretrizes que auxilie profissionais de TI e gestores a tratar logs de forma juridicamente adequada, tecnicamente eficiente e eticamente responsável.

1.2 OBJETIVOS

1.2.1 Objetivo Geral

Desenvolver uma proposta estruturada de governança e proteção de dados aplicada a logs de infraestrutura de TI, contemplando políticas, regras e diretrizes que assegurem a segurança da informação, a proteção de dados pessoais e a conformidade com a legislação e normativas vigentes, apoiando processos de tomada de decisão e resposta a incidentes.

1.2.2 Objetivos Específicos

- a) Analisar a natureza dos dados presentes em logs de infraestrutura de TI, identificando dados pessoais e dados pessoais sensíveis;
- b) Relacionar o tratamento desses dados aos fundamentos e princípios da LGPD, do GDPR e das normativas da ANPD;
- c) Propor políticas de segurança da informação aplicadas ao uso de logs, incluindo regras de acesso, retenção e descarte;
- d) Desenvolver diretrizes de anonimização, pseudonimização e sanitização de dados, com apoio pontual de código demonstrativo;
- e) Analisar a conformidade das propostas com a LGPD, o GDPR e a Resolução CD/ANPD n° 19/2024;
- f) Propor um plano de contingência e resposta a incidentes alinhado às boas práticas de segurança da informação;
- g) Refletir criticamente sobre os impactos sociais, éticos, legais e institucionais do uso de dados de logs.

1.3 DELIMITAÇÃO DO ESCOPO

O projeto concentra-se no desenvolvimento conceitual, normativo e documental de políticas e diretrizes de governança para logs de TI. Não constitui objetivo do trabalho a implementação completa de sistemas de armazenamento, processamento ou visualização de dados. O código apresentado no Capítulo 5 tem caráter exclusivamente demonstrativo, destinado a ilustrar as técnicas de anonimização e sanitização propostas, sempre contextualizadas sob a ótica legal e ética.

O objeto de estudo concreto são os logs de roteadores MikroTik RouterOS, escolhidos por sua ampla adoção no contexto brasileiro e pela riqueza de dados pessoais presentes em seus registros. As diretrizes propostas, contudo, têm aplicabilidade a qualquer equipamento ou sistema que produza logs de infraestrutura de TI.

1.4 ESTRUTURA DO TRABALHO

Este trabalho está organizado em nove capítulos. Além desta Introdução, o Capítulo 2 analisa a natureza dos dados presentes em logs de infraestrutura de TI. O Capítulo 3 apresenta a fundamentação legal e normativa aplicável. O Capítulo 4 propõe as políticas de segurança da informação para logs. O Capítulo 5 desenvolve as diretrizes de anonimização, pseudonimização e sanitização. O Capítulo 6 apresenta o plano de contingência e resposta a incidentes. O Capítulo 7 analisa a conformidade das propostas com a legislação vigente. O Capítulo 8 traz a reflexão ética, social e institucional. Por fim, o Capítulo 9 apresenta as considerações finais e os trabalhos futuros.

2 NATUREZA DOS DADOS EM LOGS DE INFRAESTRUTURA DE TI

Este capítulo analisa os tipos de dados produzidos por equipamentos de infraestrutura de TI, identificando quais categorias constituem dados pessoais nos termos da LGPD e em que circunstâncias podem ser considerados dados pessoais sensíveis.

2.1 O QUE SÃO LOGS DE INFRAESTRUTURA

Logs de infraestrutura são registros automáticos gerados por dispositivos e sistemas de TI para documentar eventos operacionais. Cada entrada de log tipicamente contém um *timestamp* (data e hora do evento), uma categoria ou severidade, e uma mensagem descritiva do evento ocorrido. Dependendo do equipamento e da configuração, os logs podem registrar conexões de rede, autenticações, erros de sistema, transferências de dados, alterações de configuração e alertas de segurança (Kent e Souppaya, 2006).

A Listing 2.1 ilustra entradas típicas de log de diferentes dispositivos de infraestrutura.

```

1 # MikroTik RouterOS - evento de firewall com IP e MAC
2 jun/15 08:23:14 firewall,info forward: in:ether1
3   src-mac 4C:CC:6A:11:22:33, proto TCP,
4   192.168.1.105:54231->203.0.113.45:443
5
6 # MikroTik RouterOS - autenticacao administrativa
7 jun/15 08:23:15 system,info,account user admin
8   logged in from 192.168.1.100 via winbox
9
10 # Servidor Linux (auth.log) - tentativa de SSH
11 Jun 15 08:24:02 servidor sshd[1234]: Failed password
12   for root from 198.51.100.12 port 42891 ssh2
13
14 # Firewall pfSense - bloqueio de pacote
15 Jun 15 08:25:11 filterlog: 5,16,0,match,block,in,
16   4,0x0,64,tcp,192.168.0.50,203.0.113.99,80

```

Listing 2.1 – Exemplos de entradas de log de dispositivos de infraestrutura de TI

2.2 CLASSIFICAÇÃO DOS DADOS PRESENTES EM LOGS

A análise dos logs de infraestrutura revela quatro categorias distintas de informação, com diferentes graus de sensibilidade sob a ótica da LGPD.

2.2.1 Dados de Identificação de Rede

Endereços IP (versões 4 e 6) e endereços MAC são os identificadores de rede mais frequentes em logs de infraestrutura. Embora tecnicamente sejam endereços de equipamentos, sua correlação com registros de provedores de acesso à internet permite identificar a pessoa natural titular da conexão, caracterizando-os como dados pessoais nos termos do art. 5º, I, da LGPD (Brasil, 2018). O Tribunal de Justiça da União Europeia consolidou esse entendimento no caso *Breyer v. Bundesrepublik Deutschland* (C-582/14), reconhecendo que endereços IP dinâmicos constituem dados pessoais quando o responsável pelo tratamento dispõe de meios razoáveis para obter a identificação do titular.

O Quadro 1 sintetiza os principais identificadores de rede e seu enquadramento legal.

Quadro 1 – Dados de identificação de rede em logs e enquadramento na LGPD

Dado	Presente em	Enquadramento LGPD
Endereço IPv4	Firewalls, roteadores, servidores	Dado pessoal (art. 5º, I) — identifica titular junto ao ISP
Endereço IPv6	Roteadores modernos, servidores	Dado pessoal (art. 5º, I) — pode ser globalmente único
Endereço MAC	Roteadores, switches, APs	Dado pessoal (art. 5º, I) — identifica hardware do titular
Porta TCP/UDP	Firewalls, proxies	Isolado: não é dado pessoal. Combinado: pode revelar comportamento
Nome de host	Servidores DNS, DHCP	Dado pessoal quando associado a pessoa identificável

Fonte: Própria dos autores (2025), com base em Brasil (2018).

2.2.2 Dados de Autenticação e Acesso

Logs de autenticação registram tentativas de acesso a sistemas e serviços, contendo nomes de usuário, horários de acesso, endereços de origem e resultado da autenticação (sucesso ou falha). Esses dados são particularmente sensíveis porque documentam o comportamento do titular: quando acessa sistemas, de onde, com qual frequência e se teve tentativas negadas. A combinação de nome de usuário, endereço IP e padrão temporal configura um perfil comportamental, cuja criação é expressamente vedada pelo princípio de não discriminação (art. 6º, IX, LGPD).

2.2.3 Dados de Comportamento e Tráfego

Logs de firewall e proxy registram os destinos das conexões realizadas pelos usuários: quais sites foram acessados, quais serviços foram utilizados, em que horários e por quanto tempo. Individualmente, uma entrada de log de destino pode parecer irrelevante; em conjunto, o histórico de navegação de um usuário constitui um perfil detalhado de seus interesses, hábitos, crenças e, eventualmente, estado de saúde ou orientação política – dados que se aproximam das categorias especiais do art. 11 da LGPD, exigindo proteção reforçada.

2.2.4 Dados de Configuração e Administração

Logs de alteração de configuração registram quem modificou o quê e quando em dispositivos de rede. Contêm nomes de usuários administradores, endereços de origem das sessões administrativas e descrição das mudanças realizadas. Esses dados são relevantes tanto para a segurança da informação (auditoria de mudanças) quanto para a proteção de dados (identificação do responsável por determinada ação).

2.3 O RISCO DE REIDENTIFICAÇÃO POR COMBINAÇÃO

Um aspecto central da análise de privacidade em logs é o risco de reidentificação por combinação de atributos. Mesmo que nenhum campo isolado permita identificar diretamente o titular, a combinação de múltiplos atributos – denominados *quasi-identificadores* – pode tornar o indivíduo identificável (Sweeney, 2002). Em um log de rede, a combinação de faixa de horário, segmento de rede, tipo de protocolo e endereço de destino pode ser suficiente para individualizar o comportamento de um usuário específico, mesmo sem que seu nome ou endereço IP apareçam explicitamente.

Essa característica implica que a avaliação de privacidade de logs não pode ser feita campo a campo: é necessária uma análise holística do conjunto de dados, considerando todas as possibilidades de combinação e o contexto em que o log será armazenado, processado ou compartilhado.

2.4 CICLO DE VIDA DO DADO NO LOG

Todo dado presente em um log percorre um ciclo de vida que começa na sua geração pelo equipamento e termina no descarte definitivo do arquivo. O Quadro 2 descreve as etapas desse ciclo e os riscos associados a cada uma.

Quadro 2 – Ciclo de vida do dado em logs de infraestrutura

Etapa	Descrição	Riscos de privacidade
Geração	Equipamento registra o evento automaticamente	Coleta excessiva de dados desnecessários
Coleta	Log é enviado a servidor centralizado (syslog, SIEM)	Transmissão sem criptografia; acesso não autorizado em trânsito
Armazenamento	Log é gravado em disco por período definido	Acesso não controlado; ausência de criptografia em repouso
Processamento	Log é analisado para fins de segurança ou auditoria	Acesso por pessoal não autorizado; uso para finalidade diferente da declarada
Compartilhamento	Log é enviado a terceiros (fornecedores, autoridades)	Transferência sem base legal; ausência de anonimização prévia
Descarte	Log é excluído ao fim do período de retenção	Exclusão incompleta; persistência em backups não controlados

Fonte: Própria dos autores (2025).

3 FUNDAMENTAÇÃO LEGAL E NORMATIVA

Este capítulo apresenta o arcabouço legal e normativo que rege o tratamento de dados pessoais em logs de infraestrutura de TI, abrangendo a LGPD, o GDPR e as normativas da ANPD, com ênfase nos dispositivos diretamente aplicáveis ao contexto do projeto.

3.1 LEI GERAL DE PROTEÇÃO DE DADOS PESSOAIS

A LGPD (Lei nº 13.709/2018) é o marco regulatório brasileiro de proteção da privacidade e dos dados pessoais (Brasil, 2018). Ela se aplica a qualquer operação de tratamento realizada por pessoa natural ou jurídica, pública ou privada, que envolva dados coletados no território nacional ou de pessoas localizadas no Brasil (art. 3º). Não há exceção expressa para dados presentes em logs técnicos: se a informação permite identificar uma pessoa natural, ela é dado pessoal e seu tratamento deve observar a lei.

3.1.1 Princípios Fundamentais Aplicáveis a Logs

O art. 6º da LGPD estabelece os princípios que devem nortear todo tratamento de dados pessoais. O Quadro 3 relaciona cada princípio às suas implicações específicas para o tratamento de logs de infraestrutura.

3.1.2 Bases Legais para Tratamento de Logs

O tratamento de dados pessoais presentes em logs deve estar fundamentado em uma das bases legais do art. 7º da LGPD. Para o contexto de logs de infraestrutura, as bases mais aplicáveis são:

- a) **Legítimo interesse** (art. 7º, IX): a organização pode tratar dados de logs para fins de segurança da informação, detecção de intrusões e auditoria, desde que os interesses legítimos do controlador prevaleçam sobre os direitos e liberdades dos titulares e que seja realizado o teste de ponderação (balancing test);
- b) **Cumprimento de obrigação legal** (art. 7º, II): determinadas legislações setoriais, como o Marco Civil da Internet (Lei nº 12.965/2014), obrigam provedores de conexão a manter logs de acesso por período mínimo de um ano (art. 13), criando base legal específica para esse tratamento;
- c) **Exercício regular de direitos** (art. 7º, VI): logs podem ser mantidos para fins de defesa em processos judiciais, administrativos ou arbitrais.

Quadro 3 – Princípios da LGPD e implicações para logs de infraestrutura

Art. 6º	Princípio	Implicação para logs de TI
Inciso I	Finalidade	O log deve ser coletado para finalidade legítima, específica e informada; não pode ser reutilizado para fins incompatíveis
Inciso II	Adequação	Os campos coletados devem ser compatíveis com a finalidade declarada; campos desnecessários não devem ser registrados
Inciso III	Minimização	Coletar apenas os dados estritamente necessários; evitar campos que identifiquem diretamente o titular quando isso não for indispensável
Inciso V	Qualidade	Manter logs íntegros e precisos pelo período necessário; evitar duplicações desnecessárias
Inciso VI	Transparência	Informar os titulares sobre a coleta de dados de rede quando viável
Inciso VII	Segurança	Adotar medidas técnicas e administrativas para proteger os logs de acessos não autorizados
Inciso VIII	Prevenção	Aplicar controles preventivos antes do armazenamento e compartilhamento
Inciso IX	Não discriminação	Impedir que logs sejam usados para perfilamento discriminatório
Inciso X	Responsabilização	Demonstrar a adoção de medidas eficazes de conformidade

Fonte: Própria dos autores (2025), com base em Brasil (2018).

3.1.3 Anonimização e seus Efeitos Legais

O art. 12 da LGPD estabelece que dados anonimizados não são considerados dados pessoais, salvo quando o processo puder ser revertido com meios técnicos razoáveis. Essa disposição cria um incentivo direto para que organizações adotem técnicas de anonimização em logs que não precisam preservar a identidade do titular para sua finalidade primária. O art. 13 permite o uso de dados anonimizados para estudos e pesquisas sem restrições adicionais.

3.1.4 Obrigações do Controlador quanto à Segurança

O art. 46 impõe ao controlador a adoção de medidas de segurança, técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou difusão. O art. 48 obriga a notificação à ANPD e aos titulares em caso de incidente de segurança que possa acarretar risco ou dano relevante.

3.2 REGULAMENTO GERAL DE PROTEÇÃO DE DADOS (GDPR)

O GDPR (Regulamento UE 2016/679) é o principal instrumento regulatório de proteção de dados da União Europeia e serviu de inspiração para a LGPD (European Parliament, 2016).

Sua análise é relevante para este projeto por duas razões: primeiro, porque muitas organizações brasileiras mantêm relações comerciais com parceiros europeus, sujeitando-se indiretamente ao GDPR; segundo, porque sua jurisprudência e orientações consolidadas pelos reguladores europeus (como o Comitê Europeu para a Proteção de Dados – EDPB) oferecem subsídios interpretativos valiosos para a aplicação da LGPD.

3.2.1 Conceitos do GDPR Aplicáveis a Logs

O GDPR introduz conceitos que complementam a análise da LGPD:

- a) **Privacy by Design e Privacy by Default** (art. 25): a proteção de dados deve ser incorporada ao design dos sistemas desde o início, e as configurações padrão devem ser as mais protetoras possível. Aplicado a logs, isso significa que equipamentos devem ser configurados para coletar o mínimo necessário por padrão, e não o máximo possível;
- b) **Relatório de Impacto à Proteção de Dados (DPIA)** (art. 35): quando o tratamento de dados puder resultar em alto risco para os direitos dos titulares – como no caso de monitoramento sistemático de atividades de rede –, é obrigatória a realização de avaliação de impacto prévia. A LGPD prevê instrumento equivalente no art. 38 (Relatório de Impacto à Proteção de Dados – RIPD);
- c) **Limitação do armazenamento**: o art. 5º, 1, e, do GDPR determina que dados pessoais sejam conservados apenas pelo período necessário para as finalidades para as quais foram coletados – princípio diretamente aplicável à definição de políticas de retenção de logs.

3.3 NORMATIVAS DA ANPD

A ANPD é a autoridade brasileira competente para fiscalizar o cumprimento da LGPD, editar normas e diretrizes e aplicar sanções (art. 55-A da LGPD). Suas resoluções e guias orientativos integram o arcabouço normativo aplicável ao tratamento de dados.

3.3.1 Resolução CD/ANPD nº 19/2024

A Resolução CD/ANPD nº 19/2024 estabelece normas complementares sobre medidas de segurança e gestão de incidentes de segurança com dados pessoais (Autoridade Nacional de Proteção de Dados (ANPD), 2024). Entre suas disposições relevantes para o presente projeto destacam-se:

- a) A obrigação de manter registros de atividades de tratamento (art. 37 da LGPD), que no contexto de logs implica documentar quais dados são coletados, por qual finalidade, por quanto tempo e quem tem acesso;

- b) A exigência de procedimentos formais para resposta a incidentes, incluindo prazos para notificação à ANPD (dois dias úteis a partir do conhecimento do incidente, nos termos da Resolução CD/ANPD n° 2/2022) e aos titulares afetados;
- c) A recomendação de adoção de medidas técnicas proporcionais ao risco, incluindo criptografia, controle de acesso baseado em funções (RBAC) e pseudonimização.

3.3.2 Guia de Anonimização e Pseudonimização da ANPD

O Guia de Boas Práticas publicado pela ANPD sobre anonimização e pseudonimização (Autoridade Nacional de Proteção de Dados (ANPD), 2022) reconhece cinco técnicas principais de desidentificação: supressão, generalização, perturbação, permutação e pseudonimização. O guia ressalta que nenhuma técnica isolada garante anonimização perfeita e recomenda a combinação de múltiplas abordagens, calibradas ao risco residual de reidentificação avaliado para cada caso concreto.

3.4 MARCO CIVIL DA INTERNET

A Lei n° 12.965/2014 (Marco Civil da Internet) estabelece obrigações específicas para provedores de conexão e de aplicações quanto à guarda de logs (Brasil, 2014). O art. 13 determina que provedores de conexão mantenham registros de conexão por um ano, em ambiente controlado e de segurança. O art. 15 impõe aos provedores de aplicações de internet a guarda de registros de acesso por seis meses. Essas obrigações criam bases legais específicas para a retenção de logs, mas não afastam a necessidade de conformidade com a LGPD quanto às demais obrigações de segurança e proteção de dados.

4 POLÍTICAS DE SEGURANÇA DA INFORMAÇÃO

Este capítulo propõe um conjunto estruturado de políticas de segurança da informação para o tratamento de logs de infraestrutura de TI, cobrindo coleta, controle de acesso, retenção, descarte, compartilhamento e documentação das atividades de tratamento – operacionalizando, para o ciclo de vida do dado apresentado no seção 2.4, os princípios da LGPD detalhados no Capítulo 3.

4.1 POLÍTICA DE CLASSIFICAÇÃO E COLETA

A coleta de logs deve observar os princípios da finalidade, adequação e minimização (art. 6º, I–III, LGPD): cada categoria de log deve ter finalidade declarada, base legal identificada e escopo de campos limitado ao estritamente necessário. O Quadro 4 associa as categorias de log definidas no Capítulo 2 à base legal aplicável e à finalidade da coleta.

Quadro 4 – Categorias de log, base legal e finalidade da coleta

Categoria de log	Base legal (art. 7º, LGPD)	Finalidade declarada
Conexão de rede (IP/MAC)	Cumprimento de obrigação legal (Marco Civil, art. 13/15)	Guarda de registros de conexão exigida por lei
Autenticação e acesso	Legítimo interesse (art. 7º, IX)	Deteção de acessos indevidos e auditoria de segurança
Firewall e tráfego	Legítimo interesse (art. 7º, IX)	Prevenção de intrusões e análise de incidentes
Configuração/administração	Legítimo interesse; exercício regular de direitos (art. 7º, VI)	Auditoria de mudanças e responsabilização de administradores

Fonte: Própria dos autores (2025), com base em Brasil (2018).

Sempre que o legítimo interesse for a base invocada, deve ser realizado e documentado o teste de ponderação (*balancing test*) entre o interesse do controlador e os direitos do titular. Campos que não sejam indispensáveis à finalidade declarada – por exemplo, corpo de mensagens ou conteúdo de pacotes – não devem ser habilitados na configuração de logging dos equipamentos, em observância ao princípio de *Privacy by Default* (subseção 3.2.1).

4.2 POLÍTICA DE CONTROLE DE ACESSO

O acesso aos logs deve seguir o princípio do menor privilégio, implementado por meio de controle de acesso baseado em funções (RBAC – *Role-Based Access Control*). O Quadro 5 define os perfis propostos e seus privilégios sobre os logs.

Quadro 5 – Perfis de acesso RBAC para logs de infraestrutura

Perfil	Privilégios	Observações
Administrador de Segurança	Leitura, configuração de retenção, exportação anonimizada	Único perfil autorizado a acessar dados não anonimizados; MFA obrigatório
Analista SOC	Leitura de logs pseudonimizados; correlação de eventos	Acesso ao <i>salt</i> de reversão negado por padrão
Auditor/Encarregado (DPO)	Leitura de registros de atividades de tratamento e trilhas de acesso	Sem acesso ao conteúdo bruto dos logs, apenas metadados de conformidade
Gestor/Coordenador	Leitura de relatórios e métricas agregadas	Sem acesso a dados individualizados

Fonte: Própria dos autores (2025).

Complementam o modelo RBAC os seguintes controles técnicos, exigidos pelo art. 46 da LGPD e pela Resolução CD/ANPD n° 19/2024: autenticação multifator (MFA) obrigatória para qualquer acesso administrativo aos sistemas de armazenamento de logs; criptografia dos logs em repouso (*at rest*) e em trânsito (*in transit*), com gerenciamento de chaves segregado do sistema de armazenamento; e trilha de auditoria imutável que registre quem acessou quais logs, quando e com qual finalidade – um "log dos logs", essencial para a demonstração de responsabilização (art. 6°, X).

4.3 POLÍTICA DE RETENÇÃO

Os prazos de retenção devem ser definidos por categoria de log, conciliando as obrigações legais mínimas com o princípio de limitação do armazenamento (subseção 3.2.1). O Quadro 6 propõe prazos de referência.

Quadro 6 – Prazos de retenção propostos por categoria de log

Categoria	Prazo	Justificativa
Registros de conexão	1 ano	Mínimo legal do art. 13 do Marco Civil da Internet
Registros de aplicação	6 meses	Mínimo legal do art. 15 do Marco Civil da Internet
Logs de segurança/firewall	12 a 18 meses	Prazo prescricional de responsabilização civil, ponderado ao volume de armazenamento
Logs de auditoria administrativa	5 anos	Alinhado a prazos de guarda documental de auditorias corporativas

Fonte: Própria dos autores (2025).

Findo o prazo, o log deve ser descartado ou anonimizado de forma irreversível (Capítulo 5), o que o remove do escopo da LGPD e permite sua retenção indefinida para fins estatísticos (art. 13). Prorrogações de prazo somente são admitidas mediante justificativa documentada, como investigação em curso ou obrigação legal superveniente.

4.4 POLÍTICA DE DESCARTE SEGURO

O descarte de logs ao final do prazo de retenção deve ser executado por meio de exclusão segura (*secure deletion*), que impeça a recuperação dos dados por ferramentas forenses, incluindo a sobrescrita de blocos de armazenamento ou a destruição criptográfica (descarte da chave de criptografia que torna os dados permanentemente ilegíveis). O procedimento deve contemplar também as cópias de segurança: a exclusão do log primário sem a exclusão correspondente em backups (seção 6.4) mantém o dado pessoal em circulação e configura descumprimento da política de retenção. Cada operação de descarte deve ser registrada – data, categoria de dado, volume e responsável – gerando evidência de conformidade sem, contudo, reter o conteúdo do dado descartado.

4.5 POLÍTICA DE COMPARTILHAMENTO

O compartilhamento de logs com terceiros – fornecedores de SIEM em nuvem, consultorias de segurança, autoridades públicas – exige base legal específica e, sempre que a finalidade do compartilhamento não exigir a identificação do titular, a aplicação prévia de anonimização ou pseudonimização (Capítulo 5). Compartilhamentos com operadores (art. 5º, VII, LGPD) devem ser formalizados em contrato que defina finalidade, medidas de segurança exigidas e obrigações de notificação de incidentes. Quando o destinatário estiver localizado no exterior, deve-se verificar se o país oferece grau de proteção adequado nos termos do art. 33 da LGPD antes da transferência. O compartilhamento com autoridades públicas, por sua vez, deve observar a base legal de cumprimento de obrigação legal ou requisição judicial, limitando-se ao escopo estritamente solicitado.

4.6 DOCUMENTAÇÃO DAS ATIVIDADES DE TRATAMENTO

Em atendimento ao art. 37 da LGPD e à Resolução CD/ANPD nº 19/2024, a organização deve manter um registro das operações de tratamento (*Records of Processing Activities*) para cada categoria de log, contemplando: (i) descrição da categoria de dado e finalidade da coleta; (ii) base legal aplicável; (iii) prazo de retenção e critério de descarte; (iv) perfis de acesso autorizados conforme o Quadro 5; (v) técnica de anonimização ou pseudonimização aplicada, quando houver; e (vi) terceiros com os quais o dado é compartilhado. Esse registro deve ser revisado periodicamente – recomenda-se periodicidade anual ou a cada alteração relevante na infraestrutura de logging – e mantido disponível para eventual fiscalização da ANPD, constituindo evidência central do princípio de responsabilização (art. 6º, X).

5 DIRETRIZES DE ANONIMIZAÇÃO, PSEUDONIMIZAÇÃO E SANITIZAÇÃO

Este capítulo desenvolve as diretrizes técnicas para a desidentificação de dados pessoais em logs de infraestrutura, apresentando as técnicas reconhecidas pela ANPD e pelo GDPR e demonstrando sua aplicação prática por meio de uma ferramenta construída com o Microsoft Presidio, framework de código aberto para detecção e anonimização de PII (Microsoft, 2023), o *MikroTik Log Anonymizer*, aplicada a logs reais de roteadores MikroTik RouterOS. A detecção combina três recognizers: o recognizer nativo do Presidio para endereços IP, um *PatternRecognizer* customizado para endereços MAC – inexistente no conjunto padrão do framework – e padrões de expressão regular para nomes de usuário em eventos típicos de autenticação MikroTik.

5.1 CONCEITOS E DISTINÇÕES

A literatura de privacidade e a legislação distinguem três operações de desidentificação com efeitos legais e técnicos distintos:

- a) **Anonimização:** processo irreversível pelo qual o dado perde completamente a possibilidade de associação a um titular, mesmo com o uso de meios técnicos razoáveis. Dados devidamente anonimizados saem do escopo de aplicação da LGPD (art. 12);
- b) **Pseudonimização:** substituição de identificadores diretos por pseudônimos, mantendo a possibilidade de reversão mediante informação adicional mantida separadamente. O dado pseudonimizado continua sendo dado pessoal nos termos da LGPD, mas seu tratamento beneficia-se de salvaguardas reduzidas em determinados contextos (art. 13, §4º);
- c) **Sanitização:** remoção ou modificação de dados em um documento ou arquivo para reduzir riscos, sem necessariamente atingir o grau de anonimização completa. Inclui técnicas como supressão de campos, truncamento e mascaramento parcial.

5.2 TÉCNICAS RECOMENDADAS POR TIPO DE DADO

A escolha da técnica de anonimização deve considerar a finalidade do log após o tratamento: se será usado apenas para auditoria interna (onde correlação entre eventos é necessária) ou para compartilhamento externo (onde a identidade do titular é irrelevante). O Quadro 7 apresenta as técnicas recomendadas para cada tipo de dado pessoal presente em logs de infraestrutura.

Quadro 7 – Técnicas de anonimização recomendadas por tipo de dado em logs

Tipo de dado	Uso interno	Compartilhamento externo	Justificativa
Endereço IP	Hash SHA-256 (pseudonimização)	Generalização ou supressão	Hash preserva correlação entre eventos sem expor o IP real
Endereço MAC	Mascaramento dos 3 primeiros octetos	Supressão completa	Os 3 primeiros octetos identificam o fabricante; os 3 últimos identificam o dispositivo
Nome de usuário	Pseudonimização por hash	Supressão	Necessário para correlação de ações do mesmo usuário em auditorias
Timestamp	Preservar (necessário)	Generalização (hora ou dia)	Precisão de segundo cria risco de quasi-identificação por combinação
Nome de host	Pseudonimização	Supressão	Pode revelar identidade organizacional ou pessoal
Porta TCP/UDP	Preservar	Preservar ou generalizar	Baixo risco isolado; relevante para análise de segurança

Fonte: Própria dos autores (2025), com base em Autoridade Nacional de Proteção de Dados (ANPD) (2022).

5.3 ARQUITETURA DA FERRAMENTA DEMONSTRATIVA

Para ilustrar a aplicação prática das diretrizes acima, foi construído o *MikroTik Log Anonymizer*, disponibilizado via interface web em Streamlit. A ferramenta adota uma arquitetura em três estágios, resumida no Quadro 8: detecção de IPs e MACs pelo Presidio Analyzer (recognizer nativo e customizado, respectivamente), detecção de nomes de usuário por expressão regular e transformação por meio dos operadores do Presidio AnonymizerEngine.

Quadro 8 – Pipeline de processamento do MikroTik Log Anonymizer

Estágio	Componente	Responsabilidade
1a	Presidio Analyzer	Detecção de endereços IP pelo recognizer nativo IP_ADDRESS (score 0,92, reforçado por palavras-chave contextuais) e de endereços MAC pelo <i>PatternRecognizer</i> customizado (score 0,95)
1b	Detecção por regex	Localização de nomes de usuário em eventos de autenticação MikroTik, categoria não coberta pelos recognizers padrão do Presidio
2	Presidio Anonymizer	Aplicação dos operadores de transformação (hash, mask, redact, replace) sobre as entidades detectadas nos estágios anteriores
–	Interface Streamlit	Upload do arquivo, configuração dos operadores e download do log anonimizado

Fonte: Própria dos autores (2025).

A combinação é deliberada: os recognizers do Presidio Analyzer oferecem detecção configurável e com pontuação de confiança para os identificadores de rede, enquanto o padrão textual dos eventos de autenticação do MikroTik – específico da plataforma – é mais eficientemente capturado por expressão regular dedicada. Os operadores do Presidio AnonymizerEngine, por sua vez, garantem a semântica e a configurabilidade das transformações aplicadas às entidades detectadas.

5.4 MOTOR DE ANONIMIZAÇÃO (CORE_ANONYMIZER.PY)

O módulo `core_anonymizer.py` concentra toda a lógica de desidentificação, organizada em estruturas de dados de configuração/resultado e padrões de detecção por expressão regular.

```

1 @dataclass
2 class AnonymizerConfig:
3     ip_mode: AnonymizationMode = "hash"      # hash | mask | redact |
4         replace
5     mac_mode: AnonymizationMode = "mask"
6     redact_usernames: bool = True
7     hash_type: str = "sha256"                # sha256 | sha512 | md5
8     mask_char: str = "*"
9
10 @dataclass
11 class ProcessingResult:
12     original_lines: int = 0
13     processed_lines: int = 0
14     ips_found: int = 0
15     macs_found: int = 0
16     usernames_found: int = 0
17     elapsed_seconds: float = 0.0
18     sample_before: list = field(default_factory=list)
19     sample_after: list = field(default_factory=list)
20     output_bytes: bytes = b""

```

Listing 5.1 – Estruturas de dados de configuracao e resultado

O tipo `AnonymizationMode` é um Literal Python que restringe os valores aceitos a "hash", "mask", "redact" e "replace", garantindo validação estática por ferramentas como `mypy`. Como os endereços IP e MAC são detectados pelos recognizers do Presidio Analyzer (seção 5.5), a única expressão regular própria do módulo cobre os padrões de nome de usuário em eventos de autenticação MikroTik, categoria não coberta pelos recognizers padrão do framework:

```

1 # Padroes de username em eventos MikroTik
2 _USERNAME_PATTERNS = [

```

```

3 (re.compile(r"\buser\s+(\w+)\s+logged\b", re.IGNORECASE),
4   "user <USUARIO> logged"),
5 (re.compile(r"\bchanged\s+by\s+(\w+)\b", re.IGNORECASE),
6   "changed by <USUARIO>"),
7 (re.compile(r"\bfailed\s+login\s+attempt\s+for\s+(\w+)\b",
8   re.IGNORECASE), "failed login attempt for <USUARIO>"),
9 ]

```

Listing 5.2 – Padroes de detecção de username por expressão regular

A classe MikroTikAnonymizer implementa o método `process_file`, que itera sobre todas as linhas do log, aplicando sequencialmente os três estágios de anonimização:

```

1 for i, line in enumerate(lines):
2     # 1. Usernames -- Art. 6 III (Minimizacao)
3     if config.redact_usernames:
4         for pat, repl in _USERNAME_PATTERNS:
5             new_line, n = pat.subn(repl, line)
6             if n:
7                 line = new_line
8                 result.usernames_found += n
9
10    # 2. IPs e MACs -- Art. 6 VII, VIII e IX
11    # (Seguranca / Prevencao / Nao discriminacao)
12    analyzer_results = analyzer.analyze(
13        text=line, entities=["IP_ADDRESS", "MAC_ADDRESS"], language
14        ="en"
15    )
16    if analyzer_results:
17        result.ips_found += sum(
18            1 for r in analyzer_results if r.entity_type == "
19            IP_ADDRESS"
20        )
21        result.macs_found += sum(
22            1 for r in analyzer_results if r.entity_type == "
23            MAC_ADDRESS"
24        )
25        line = anonymizer.anonymize(
26            text=line, analyzer_results=analyzer_results,
27            operators=operators
28        ).text
29    out_lines.append(line)

```

Listing 5.3 – Pipeline de processamento linha a linha

A ordem dos estágios é deliberada: usernames são processados primeiro por expressão regular, antes de o restante da linha ser submetido ao Presidio Analyzer, evitando que fragmentos de nomes de usuário sejam erroneamente capturados pelos recognizers de IP ou MAC.

5.5 RECOGNIZERS DO PRESIDIO: IP NATIVO E MAC CUSTOMIZADO

Para endereços IP, utiliza-se o recognizer nativo `IP_ADDRESS` do Presidio Analyzer, com a lista de palavras-chave contextuais (`context`) ampliada para termos comuns em logs de rede – como `"src"`, `"dst"`, `"ip"` e `"endereço"` –, elevando a pontuação de confiança das detecções para 0,92 nos testes realizados com o log real.

Já para endereços MAC, constatou-se que o Microsoft Presidio, em sua versão padrão (`presidio-analyzer >= 2.2.355`), não inclui um recognizer nativo – resultado técnico relevante do projeto. Esse tipo de dado é tratado como PII de alta sensibilidade pela LGPD (art. 6º, IX), pois permite o perfilamento de dispositivos específicos ao longo do tempo. A implementação do recognizer customizado segue a interface `PatternRecognizer` do Presidio e é registrada no `AnalyzerEngine` antes do uso, ao lado do recognizer nativo de IP:

```

1 from presidio_analyzer import PatternRecognizer, Pattern
2
3 mac_pattern = Pattern(
4     name="MAC_ADDRESS",
5     regex=r"\b([0-9A-Fa-f]{2}:){5}[0-9A-Fa-f]{2}\b",
6     score=0.95
7 )
8
9 mac_recognizer = PatternRecognizer(
10     supported_entity="MAC_ADDRESS",
11     patterns=[mac_pattern],
12     context=["mac", "address", "device", "src-mac", "dst-mac"]
13 )
14 # Registrar no AnalyzerEngine antes do uso:
15 # analyzer.registry.add_recognizer(mac_recognizer)

```

Listing 5.4 – Recognizer customizado para endereços MAC

O *score* de 0,95 foi definido empiricamente após testes com o log real: a expressão regular é suficientemente estrita para o formato MAC que falsos positivos não foram observados, justificando um score próximo ao máximo. As palavras de contexto ampliam a precisão em casos onde o formato apareça em texto narrativo.

5.6 OPERADORES DE ANONIMIZAÇÃO

Os operadores disponibilizados ao usuário na interface são configurados como objetos `OperatorConfig` do `Presidio AnonymizerEngine`, mapeados por tipo de entidade detectada. Para IPs, quatro modos são oferecidos:

```

1 from presidio_anonymizer.entities import OperatorConfig
2
3 def _make_ip_operator(mode: str, hash_type: str) -> OperatorConfig:
4     if mode == "hash":
5         # Pseudonimizacao deterministica: mesmo IP -> mesmo hash
6         return OperatorConfig("hash", {"hash_type": hash_type})
7     if mode == "mask":
8         return OperatorConfig("mask", {
9             "masking_char": "*", "chars_to_mask": 9, "from_end":
10                False
11        })
12     if mode == "redact":
13         return OperatorConfig("redact", {})
14     return OperatorConfig("replace", {"new_value": "<IP_ANONIMIZADO
15        >"})

```

Listing 5.5 – Fabrica de operadores Presidio para enderecos IP

A propriedade determinística do operador hash é essencial para a análise de incidentes: o analista pode agrupar todos os eventos originados de um mesmo IP sem conhecer o endereço real. Para MACs, a mesma lógica de quatro modos é aplicada, preservando por padrão os três octetos finais do dispositivo:

```

1 def _make_mac_operator(mode: str) -> OperatorConfig:
2     if mode == "hash":
3         return OperatorConfig("hash", {"hash_type": "sha256"})
4     if mode == "mask":
5         # Mascara os 3 primeiros octetos (OUI/fabricante)
6         # Preserva os 3 ultimos (identificador do dispositivo)
7         return OperatorConfig("mask", {
8             "masking_char": "*", "chars_to_mask": 9, "from_end":
9                False
10        })
11     if mode == "redact":
12         return OperatorConfig("redact", {})
13     return OperatorConfig("replace", {"new_value": "<
14        MAC_ANONIMIZADO>"})

```

```

14 operators = {
15     "IP_ADDRESS": _make_ip_operator(config.ip_mode, config.
        hash_type),
16     "MAC_ADDRESS": _make_mac_operator(config.mac_mode),
17 }

```

Listing 5.6 – Fabrica de operadores Presidio para enderecos MAC

Os três primeiros octetos do MAC formam o OUI (*Organizationally Unique Identifier*), que identifica o fabricante e por si só não identifica o titular; os três finais identificam o dispositivo específico e constituem o dado pessoal sensível. O resultado `***:***:***:XX:XX:XX` remove a possibilidade de perfilamento sem eliminar a utilidade do dado para análise de topologia de rede.

5.7 PSEUDONIMIZAÇÃO POR HASH COM SALT

Para cenários que exigem garantia adicional contra ataques de dicionário ou pré-computação (*rainbow tables*), recomenda-se complementar o hash com um *salt* – valor aleatório concatenado ao dado antes do resumo criptográfico – mantido separadamente dos logs, em cofre de segredos com acesso restrito (Dwork e Roth, 2014).

```

1 import hashlib, secrets
2
3 SALT = secrets.token_hex(32) # armazenado separadamente dos logs
4
5 def pseudonimizar_ip(ip: str) -> str:
6     """Mesmo IP + salt sempre gera o mesmo hash (correlacao
7     preservada); sem o salt, o hash e irreversivel por dicionario."
8     ""
9     return hashlib.sha256((SALT + ip).encode("utf-8")).hexdigest()

```

Listing 5.7 – Pseudonimizacao de IP com SHA-256 e salt

5.8 GENERALIZAÇÃO TEMPORAL

A generalização temporal trunca a precisão dos *timestamps*, reduzindo o risco de quasi-identificação por combinação de horário com outros atributos. Para compartilhamento externo, recomenda-se truncar ao nível de hora ou dia.

```

1 _TS_RE = re.compile(r"([a-z]{3}/\d{2}\s+)(\d{2}:\d{2}:\d{2})", re.
    IGNORECASE)
2
3 def generalizar_timestamp(linha: str, nivel: str = "hora") -> str:
4     """nivel='hora' -> preserva hh:00:00; nivel='dia' -> remove
    horario."""

```

```

5     def substituir(m):
6         if nivel == "hora":
7             return m.group(1) + m.group(2).split(":")[0] + ":00:00"
8         return m.group(1).strip()
9     return _TS_RE.sub(substituir, linha)

```

Listing 5.8 – Generalizacao temporal de timestamps em logs MikroTik

5.9 INTERFACE WEB (APP.PY)

A interface web foi desenvolvida em Streamlit e estruturada em quatro áreas funcionais:

- Painel lateral de configuração:** o usuário seleciona, de forma independente, o método de anonimização para IPs (com seleção do algoritmo de hash quando aplicável), para MACs e o comportamento para usernames. O painel exibe também os artigos LGPD cobertos por cada configuração, servindo como guia de conformidade embutido na interface;
- Área de upload:** aceita arquivos .log, .txt e .zip. Arquivos comprimidos são descompactados em memória (RAM), sem gravação em disco, antes do processamento;
- Painel de resultados:** exibe métricas da execução (linhas processadas, contagens por tipo de PII, tempo decorrido e tamanho do log anonimizado) e um preview lado a lado de até 10 linhas com PII detectada, antes e depois da anonimização, permitindo auditoria visual imediata;
- Download:** o log anonimizado é disponibilizado para download direto no navegador, com nomenclatura automática (<nome-original>_lgpd_anonimizado.log).

O processamento assíncrono com barra de progresso (atualizada a cada 0,5% do arquivo) mantém a interface responsiva durante o processamento de arquivos grandes. O motor é carregado com cache (@st.cache_resource), evitando reinicializações desnecessárias entre execuções consecutivas.

5.10 RESULTADOS DA VALIDAÇÃO

O pipeline completo foi validado com um log real de roteador MikroTik em produção, contendo 738.846 linhas e cerca de 50 MB de dados brutos. O processamento anonimizou 258.688 IPs, 148.120 MACs e 73.867 usernames em aproximadamente 9 segundos em hardware convencional, demonstrando viabilidade operacional para uso cotidiano. A decisão de preservar os *timestamps* originais mereceu análise específica: embora possam contribuir para reidentificação em combinação com outros atributos (seção 2.3), sua supressão eliminaria a utilidade primária dos logs para análise de incidentes – optou-se por mantê-los para uso interno, com generalização temporal recomendada para cenários de compartilhamento externo.

Como limitação, a ferramenta não trata o risco de reidentificação por combinação de quasi-identificadores (horário + tipo de evento + segmento de rede). Para cenários de alta sensibilidade, recomenda-se complementar com técnicas de privacidade diferencial, implementáveis via *SmartNoise* ou *Google Differential Privacy Library* (Dwork e Roth, 2014).

5.11 DIRETRIZES PARA APLICAÇÃO

Com base nas técnicas descritas, propõem-se as seguintes diretrizes para a organização que adotar as políticas deste projeto:

- a) Aplicar anonimização automaticamente no momento da coleta, sempre que a finalidade primária do log não exigir a identidade do titular – eliminando o risco na origem;
- b) Para logs que precisam preservar a capacidade de correlação (uso interno de segurança), adotar pseudonimização por hash com *salt*; para compartilhamento externo, aplicar supressão ou generalização;
- c) Manter separação física ou lógica entre o *salt* e os logs pseudonimizados – o acesso ao *salt* deve ser restrito ao administrador de segurança;
- d) Documentar o processo de anonimização aplicado a cada categoria de log, incluindo o algoritmo utilizado, os campos tratados e a data de aplicação, para fins de demonstração de conformidade (art. 6º, X, LGPD – responsabilização), integrando o registro de atividades de tratamento do seção 4.6;
- e) Revisar anualmente a efetividade das técnicas adotadas, considerando a evolução das capacidades técnicas de reidentificação.

6 PLANO DE CONTINGÊNCIA E RESPOSTA A INCIDENTES

Este capítulo propõe um plano de contingência e resposta a incidentes de segurança envolvendo logs de infraestrutura de TI, alinhado às boas práticas internacionais, à LGPD e à Resolução CD/ANPD nº 19/2024.

6.1 FUNDAMENTAÇÃO E OBJETIVOS DO PLANO

Um incidente de segurança envolvendo logs de infraestrutura pode assumir diversas formas: acesso não autorizado aos arquivos de log, exfiltração de dados por agente malicioso, destruição acidental ou intencional de registros, ou divulgação indevida a terceiros. Em todos esses casos, a LGPD impõe obrigações específicas: o art. 48 determina que o controlador comunique à ANPD e aos titulares afetados a ocorrência de incidente de segurança que possa acarretar risco ou dano relevante, em prazo razoável (Brasil, 2018).

A Resolução CD/ANPD nº 2/2022 operacionalizou esse prazo em dois dias úteis a partir do conhecimento do incidente para a comunicação inicial à ANPD, com prazo adicional para comunicação complementar. O plano proposto neste capítulo estrutura os procedimentos necessários para cumprir essas obrigações e minimizar os danos decorrentes de incidentes.

6.2 CLASSIFICAÇÃO DE INCIDENTES

Os incidentes relacionados a logs de infraestrutura são classificados em três níveis de severidade, conforme o potencial de dano aos titulares e à organização.

Quadro 9 – Classificação de incidentes envolvendo logs de infraestrutura

Nível	Classificação	Exemplos	Ação imediata
1	Crítico	Exfiltração confirmada de logs com dados pessoais; ransomware em servidor de logs	Isolar sistema, acionar equipe de resposta, notificar ANPD em até 2 dias úteis
2	Grave	Acesso não autorizado a logs (sem confirmação de exfiltração); falha de criptografia em repouso	Investigar escopo, preservar evidências, avaliar necessidade de notificação
3	Moderado	Acesso por usuário não autorizado internamente; compartilhamento indevido de log bruto	Revogar acesso, documentar ocorrência, corrigir controle falho

Fonte: Própria dos autores (2025).

6.3 FASES DO PLANO DE RESPOSTA

O plano de resposta a incidentes é estruturado em seis fases, baseadas no modelo do NIST SP 800-61 (Cichonski et al., 2012) e adaptadas ao contexto de logs de infraestrutura e às obrigações da LGPD.

6.3.1 Fase 1 — Preparação

A preparação é a fase preventiva, realizada antes de qualquer incidente. Inclui:

- a) Definição e treinamento de uma Equipe de Resposta a Incidentes (ERI), com papéis claramente atribuídos: Coordenador, Analista Técnico, Responsável pelo DPO/jurídico e Comunicador;
- b) Implantação de ferramentas de monitoramento de integridade dos arquivos de log (FIM – *File Integrity Monitoring*), que detectam modificações não autorizadas em tempo real;
- c) Definição prévia dos critérios de notificação à ANPD e aos titulares, incluindo modelos de comunicação aprovados pela assessoria jurídica;
- d) Realização de exercícios de simulação (*tabletop exercises*) ao menos uma vez por ano.

6.3.2 Fase 2 — Identificação

A fase de identificação começa quando um evento anômalo é detectado. As ações incluem:

- a) Confirmar se o evento constitui efetivamente um incidente de segurança ou um falso positivo;
- b) Determinar o escopo inicial: quais logs foram afetados, qual o volume de dados potencialmente comprometidos e quais categorias de dados pessoais estão envolvidas;
- c) Registrar o horário de identificação do incidente – o prazo de dois dias úteis para notificação à ANPD começa a contar a partir desse momento.

6.3.3 Fase 3 — Contenção

A contenção visa limitar o dano sem destruir evidências:

- a) Contenção de curto prazo: isolar o sistema afetado da rede, revogar acessos suspeitos, bloquear canais de exfiltração identificados;
- b) Contenção de longo prazo: implantar controles compensatórios (como autenticação adicional ou restrição de acesso temporária) enquanto a causa raiz é investigada;

- c) Preservar todos os registros de evidência (logs do sistema operacional, logs de acesso, registros de firewall) em mídia somente-leitura, para uso em investigação forense e eventual processo legal.

6.3.4 Fase 4 — Investigação e Erradicação

- a) Conduzir análise forense para determinar a causa raiz do incidente, o vetor de ataque e o escopo definitivo dos dados comprometidos;
- b) Identificar e remover o agente causador (malware, conta comprometida, misconfiguration);
- c) Avaliar se o incidente se enquadra na obrigação de notificação à ANPD, considerando os critérios de risco e dano relevante estabelecidos pela Resolução CD/ANPD n° 2/2022.

6.3.5 Fase 5 — Notificação

Para incidentes de nível 1 (Crítico), a notificação à ANPD deve ocorrer em até dois dias úteis a partir da identificação do incidente. A comunicação inicial deve conter:

- a) Descrição da natureza do incidente e das categorias e volume de dados pessoais afetados;
- b) Identificação dos titulares afetados (ou estimativa, quando não for possível determinar com precisão);
- c) Medidas técnicas e organizacionais adotadas para mitigar os efeitos do incidente;
- d) Nome e dados de contato do Encarregado (DPO).

A comunicação aos titulares deve ocorrer quando o incidente puder acarretar risco ou dano relevante a eles, sendo realizada de forma clara e acessível, sem uso de linguagem técnica que dificulte a compreensão.

6.3.6 Fase 6 — Recuperação e Lições Aprendidas

- a) Restaurar os sistemas afetados a partir de backups verificados e íntegros;
- b) Implementar as correções identificadas durante a investigação para prevenir recorrência;
- c) Elaborar relatório pós-incidente documentando: cronologia, causa raiz, impacto, ações tomadas, lições aprendidas e melhorias implementadas;
- d) Revisar e atualizar o plano de resposta com base nos aprendizados do incidente.

6.4 BACKUPS E CONTINUIDADE

Os logs devem ser incluídos na política de backup da organização, com as seguintes especificações:

- a) Backups devem ser realizados com frequência compatível com o volume de dados gerado e o prazo de retenção definido;
- b) Os backups de logs devem ser criptografados com a mesma ou superior nível de proteção dos logs primários;
- c) Backups devem ser armazenados em localização física ou lógica separada dos logs primários, para garantir disponibilidade em caso de ransomware ou desastre físico;
- d) A integridade dos backups deve ser verificada periodicamente por meio de restaurações de teste documentadas.

7 ANÁLISE DE CONFORMIDADE

Este capítulo analisa em que medida as políticas e diretrizes propostas nos capítulos anteriores atendem às exigências da LGPD, do GDPR e das normativas da ANPD, identificando pontos de convergência, divergência e lacunas que devem ser consideradas na implementação.

7.1 CONFORMIDADE COM A LGPD

A Tabela 1 apresenta a análise artigo por artigo dos principais dispositivos da LGPD aplicáveis ao tratamento de logs, indicando como cada um é endereçado pelas propostas deste trabalho.

Tabela 1 – Análise de conformidade com a LGPD

Artigo	Dispositivo	Exigência	Endereçamento nas propostas
Art. 6º, I–X	Princípios	Observância dos dez princípios no tratamento	Cap. 4: políticas baseadas nos princípios; Cap. 5: técnicas alinhadas à minimização
Art. 7º	Bases legais	Tratamento fundado em base legal específica	Cap. 4: identificação das bases legais por categoria de log
Art. 12	Anonimização	Dados anonimizados saem do escopo da LGPD	Cap. 5: diretrizes e código para anonimização efetiva
Art. 37	Registros	Manutenção de registro das operações de tratamento	Cap. 4, seção 4.6: documentação obrigatória das atividades
Art. 38	RIPD	Avaliação de impacto em tratamentos de alto risco	Cap. 3: identificação da obrigatoriedade do RIPD para monitoramento sistemático
Art. 46	Segurança	Medidas técnicas e administrativas de proteção	Cap. 4: RBAC, criptografia, MFA, trilha de auditoria
Art. 48	Notificação	Comunicação de incidentes à ANPD e titulares	Cap. 6: plano de resposta com fase de notificação estruturada

Fonte: Própria dos autores (2025), com base em Brasil (2018).

7.2 CONFORMIDADE COM O GDPR

O GDPR estabelece padrões em alguns aspectos mais detalhados do que a LGPD, especialmente quanto ao Privacy by Design (art. 25) e ao DPIA (art. 35). A Tabela 2 compara os dois regulamentos nos pontos mais relevantes para o contexto de logs.

As propostas deste trabalho adotam o padrão mais rigoroso quando há divergência entre LGPD e GDPR, garantindo que organizações sujeitas a ambas as legislações possam usar as políticas propostas sem adaptação.

Tabela 2 – Comparativo LGPD × GDPR para tratamento de logs de infraestrutura

Aspecto	LGPD	GDPR
Escopo de aplicação	Dados de titulares no Brasil	Dados de titulares na UE
Conceito de dado pessoal	Art. 5º, I: identificado ou identificável	Art. 4º, 1: mesma definição; inclui explicitamente dados de localização e identificadores online
Privacy by Design	Implícito no art. 46	Explícito no art. 25
Avaliação de impacto	Art. 38: RIPD, a critério da ANPD	Art. 35: DPIA obrigatório para monitoramento sistemático
Prazo de notificação	Resolução CD/ANPD nº 2/2022: 2 dias úteis	Art. 33: 72 horas
Sanção máxima	2% do faturamento, até R\$ 50 milhões	4% do faturamento mundial anual ou € 20 milhões
DPO	Art. 41: Encarregado (recomendado)	Art. 37–39: DPO (obrigatório em determinados casos)

Fonte: Própria dos autores (2025), com base em Brasil (2018) e European Parliament (2016).

7.3 CONFORMIDADE COM A RESOLUÇÃO CD/ANPD Nº 19/2024

A Resolução CD/ANPD nº 19/2024 reforça as obrigações de segurança e resposta a incidentes já previstas na LGPD, com maior detalhamento operacional (Autoridade Nacional de Proteção de Dados (ANPD), 2024). Os pontos de maior relevância para este projeto são:

- a) **Inventário de tratamento:** a resolução reforça a obrigação de manutenção de registros detalhados das atividades de tratamento, endereçada na Seção 4.6 do Capítulo 4;
- b) **Medidas de segurança proporcionais ao risco:** a resolução adota a abordagem de risco como critério para definir as medidas técnicas necessárias. As políticas do Capítulo 4 seguem essa abordagem ao categorizar dados por sensibilidade e definir controles proporcionais;
- c) **Gestão de incidentes:** a resolução detalha os requisitos do processo de notificação, integralmente incorporados no plano do Capítulo 6.

7.4 LACUNAS E RECOMENDAÇÕES ADICIONAIS

A análise de conformidade revela três lacunas que as organizações devem considerar ao implementar as políticas propostas:

- a) **RIPD/DPIA:** as políticas propõem a realização do RIPD para tratamentos de alto risco, mas não incluem um modelo de relatório. Recomenda-se que cada organização elabore seu próprio RIPD seguindo as orientações da ANPD, utilizando o guia publicado em 2023;
- b) **Transferência internacional:** organizações que utilizam serviços de nuvem internacionais para armazenar logs devem verificar se o país de destino oferece nível

adequado de proteção nos termos do art. 33 da LGPD, o que não foi detalhado neste trabalho por depender do contexto específico de cada organização;

- c) **Direitos dos titulares:** os logs podem ser alvo de solicitações de acesso, correção ou eliminação por parte dos titulares (arts. 17–22, LGPD). As políticas propostas não detalham os procedimentos para atendimento a essas solicitações no contexto específico de logs, o que deve ser desenvolvido como complemento.

8 REFLEXÃO ÉTICA, SOCIAL E INSTITUCIONAL

Este capítulo propõe uma reflexão crítica sobre os impactos sociais, éticos, legais e institucionais do uso de dados de logs de infraestrutura de TI, indo além da dimensão técnica e legal para examinar as implicações mais amplas das práticas de logging sobre indivíduos, organizações e a sociedade.

8.1 O LOG COMO INSTRUMENTO DE VIGILÂNCIA

Logs de infraestrutura são, em sua essência, registros de comportamento. Cada entrada documenta o que uma pessoa fez, quando fez, de onde fez e com quem interagiu na rede. Acumulados ao longo do tempo, esses registros constroem um retrato detalhado dos hábitos, interesses e relações de um indivíduo – sem que ele tenha, na maioria dos casos, consciência dessa documentação.

Essa característica aproxima os logs de infraestrutura do conceito de vigilância em massa discutido por Zuboff (2019), que descreve como a coleta sistemática de dados comportamentais pode se tornar um instrumento de controle social quando não submetida a limites claros. A diferença entre logging legítimo para fins de segurança e vigilância injustificada reside precisamente na existência – ou ausência – de políticas claras de finalidade, minimização, retenção e acesso.

A questão ética central não é se logs devem existir: eles são necessários para a operação segura de redes. A questão é *até que ponto* é legítimo coletar, reter e analisar dados de comportamento de rede, e *quem* tem o direito de fazer isso, com quais finalidades e sob quais controles.

8.2 ASSIMETRIA DE PODER E CONSENTIMENTO

Existe uma assimetria de poder estrutural entre quem opera a rede e quem a utiliza. O administrador de rede tem acesso a uma visão completa do comportamento digital dos usuários; estes, em geral, desconhecem o que é registrado, por quanto tempo e a quem é disponibilizado. Essa assimetria é agravada pelo fato de que, em muitos contextos – como redes corporativas e provedores de internet –, o usuário não tem escolha real sobre o uso da rede: sua participação profissional ou social depende do acesso.

O princípio da transparência (art. 6º, VI, LGPD) e o direito à informação dos titulares (art. 9º) são instrumentos legais para reduzir essa assimetria, mas sua efetividade depende de comunicação genuinamente clara e acessível – não de cláusulas contratuais em linguagem jurídica que poucos leem ou compreendem. Do ponto de vista ético, as organizações têm a responsabilidade de ir além do mínimo legal e informar ativamente seus usuários sobre o que é

registrado e por quê.

8.3 RISCOS SOCIAIS DO USO INADEQUADO DE LOGS

O uso inadequado de logs de infraestrutura pode gerar danos sociais que vão além do indivíduo afetado:

- a) **Discriminação algorítmica:** padrões de acesso a sites ou serviços extraídos de logs podem ser usados para inferir características protegidas dos usuários (religião, orientação política, condição de saúde), criando base para discriminação em processos de contratação, concessão de crédito ou acesso a serviços;
- b) **Perseguição e assédio:** logs que revelam padrões de localização ou comunicação podem ser usados para rastrear indivíduos, com riscos especiais para populações vulneráveis como jornalistas, ativistas e vítimas de violência doméstica;
- c) **Chilling effect:** a consciência de que comportamentos na rede são registrados pode inibir a expressão legítima, a busca de informação e o exercício de direitos, mesmo quando o usuário não está fazendo nada ilícito. Esse efeito de autocensura é documentado na literatura de direitos digitais como uma das consequências mais danosas da vigilância em massa (Solove, 2011).

8.4 RESPONSABILIDADE INSTITUCIONAL

As organizações que operam infraestrutura de rede ocupam uma posição de confiança em relação aos seus usuários. Essa confiança cria responsabilidades que transcendem o cumprimento formal da lei:

- a) **Responsabilidade proativa:** não é suficiente aguardar que uma violação ocorra para adotar medidas de proteção. A abordagem de Privacy by Design exige que a proteção de dados seja incorporada ao design dos sistemas desde o início, antes de qualquer coleta;
- b) **Cultura organizacional:** políticas de proteção de dados são efetivas apenas quando internalizadas pela equipe. O treinamento regular, a liderança pelo exemplo e a criação de canais para reporte de preocupações éticas são tão importantes quanto os controles técnicos;
- c) **Prestação de contas:** a responsabilização (art. 6º, X, LGPD) não é apenas uma obrigação de documentar o que foi feito – é um compromisso de demonstrar ativamente que o tratamento de dados respeita os direitos dos titulares. Organizações que tratam esse princípio como burocracia perdem a oportunidade de construir confiança genuína.

8.5 O PAPEL DO PROFISSIONAL DE COMPUTAÇÃO

Os profissionais de ciência da computação e engenharia de software ocupam posição central na concretização – ou na violação – dos direitos de privacidade. São eles que configuram os níveis de logging dos equipamentos, que desenvolvem os sistemas de armazenamento e análise de logs, e que definem quais campos são capturados e por quanto tempo são retidos. Cada decisão técnica tem implicações éticas e legais que muitas vezes não são visíveis para quem toma a decisão.

A formação em ciência da computação inclui, portanto, a responsabilidade de desenvolver consciência crítica sobre essas implicações. A privacidade não é um problema de compliance a ser resolvido pelo departamento jurídico: é uma dimensão de qualidade do software e da infraestrutura que deve ser considerada desde as fases iniciais de projeto. O profissional que implementa políticas de logging sem questionar sua necessidade, proporcionalidade e impacto sobre os titulares está tomando uma decisão ética – mesmo que não perceba isso como tal.

8.6 CONTRIBUIÇÃO DO PROJETO PARA A SOCIEDADE

Este projeto contribui para a redução da assimetria entre organizações e titulares ao propor um conjunto de políticas e diretrizes que, se adotadas, tornam o tratamento de dados de logs mais transparente, proporcional e seguro. A disponibilização das diretrizes técnicas de anonimização com código demonstrativo reduz a barreira de entrada para organizações que desejam conformar-se com a LGPD mas carecem de recursos para contratar consultorias especializadas.

Do ponto de vista acadêmico, o projeto ilustra como a ciência da computação pode e deve contribuir para a proteção de direitos fundamentais – não apenas como disciplina técnica, mas como campo de conhecimento com responsabilidades sociais inerentes ao poder que seus profissionais exercem sobre a infraestrutura digital da sociedade.

9 CONSIDERAÇÕES FINAIS

Este trabalho desenvolveu uma proposta estruturada de governança e proteção de dados aplicada a logs de infraestrutura de tecnologia da informação, respondendo ao problema norteador proposto: como estruturar políticas, regras e diretrizes para o uso, anonimização, sanitização, retenção e compartilhamento de dados de logs, de forma a garantir conformidade legal, apoiar a tomada de decisão em segurança da informação e subsidiar planos de resposta a incidentes.

9.1 SÍNTESE DAS CONTRIBUIÇÕES

O projeto produziu as seguintes contribuições concretas:

- a) **Análise da natureza dos dados** (Capítulo 2): identificação e classificação dos tipos de dados pessoais presentes em logs de roteadores, servidores e firewalls, com ênfase no risco de reidentificação por combinação de quasi-identificadores – um aspecto frequentemente negligenciado em abordagens campo a campo;
- b) **Fundamentação legal e normativa** (Capítulo 3): mapeamento detalhado dos dispositivos da LGPD, do GDPR e das normativas da ANPD (incluindo a Resolução CD/ANPD n° 19/2024) aplicáveis ao tratamento de logs, com análise das bases legais disponíveis e das obrigações do controlador;
- c) **Políticas de segurança** (Capítulo 4): conjunto estruturado de políticas de coleta, acesso (com modelo RBAC), retenção (com prazos fundamentados), descarte seguro, compartilhamento e documentação de atividades de tratamento – cobrindo todo o ciclo de vida do dado no log;
- d) **Diretrizes de anonimização** (Capítulo 5): técnicas de desidentificação recomendadas por tipo de dado, com código Python demonstrativo para pseudonimização por hash com *salt*, mascaramento de endereços MAC, generalização temporal de timestamps e pipeline de anonimização com Microsoft Presidio;
- e) **Plano de contingência** (Capítulo 6): plano de resposta a incidentes em seis fases, alinhado ao NIST SP 800-61 e às obrigações de notificação da LGPD e da Resolução CD/ANPD n° 2/2022;
- f) **Análise de conformidade** (Capítulo 7): avaliação artigo por artigo do alinhamento das propostas com LGPD, GDPR e Resolução CD/ANPD n° 19/2024, com identificação de lacunas e recomendações adicionais;
- g) **Reflexão ética** (Capítulo 8): discussão crítica sobre logging como instrumento de vigilância, assimetria de poder, riscos sociais do uso inadequado de logs e responsabilidade dos profissionais de computação.

9.2 CONCLUSÕES

Os objetivos específicos propostos foram integralmente alcançados. O trabalho demonstrou que o tratamento de dados pessoais em logs de infraestrutura é uma questão simultaneamente técnica, legal e ética, que exige uma abordagem integrada – não basta implementar criptografia sem definir políticas de acesso; não basta ter políticas sem treinamento; não basta cumprir a lei sem refletir sobre os impactos reais sobre as pessoas.

A análise comparativa entre LGPD e GDPR revelou que, em vários aspectos, a legislação brasileira é menos prescritiva que o regulamento europeu – especialmente quanto ao Privacy by Design e à obrigatoriedade do RIPD. Essa menor prescritividade não deve ser interpretada como permissividade: o espírito da LGPD, expresso em seus princípios, aponta para o mesmo nível de proteção. As políticas propostas adotaram o padrão mais rigoroso em todos os pontos de divergência, garantindo compatibilidade com ambas as legislações.

O uso do Microsoft Presidio como ferramenta demonstrativa evidenciou tanto as possibilidades quanto as limitações das soluções de código aberto para anonimização de logs: a ferramenta é eficaz e extensível, mas exige adaptação para o contexto específico de infraestrutura de rede – como demonstrado pela necessidade de implementar um reconhecedor customizado para endereços MAC, ausente em seu conjunto padrão.

9.3 TRABALHOS FUTUROS

A partir das lacunas identificadas e das limitações do escopo deste projeto, propõem-se os seguintes desdobramentos:

- Desenvolver um modelo de Relatório de Impacto à Proteção de Dados (RIPD) específico para operações de logging em infraestrutura de TI, seguindo as orientações da ANPD;
- Elaborar procedimentos detalhados para atendimento a solicitações de direitos dos titulares (acesso, correção, eliminação) no contexto de dados presentes em logs;
- Estender as diretrizes de anonimização para logs de outros fabricantes e sistemas (Cisco IOS, pfSense, Nginx, Apache), ampliando a aplicabilidade do conjunto de políticas;
- Implementar e avaliar as políticas propostas em um ambiente real controlado, mensurando o impacto sobre a operação de segurança e o esforço de conformidade;
- Desenvolver um questionário de autoavaliação de maturidade em governança de logs, permitindo que organizações identifiquem rapidamente suas lacunas de conformidade em relação às políticas propostas;

- Investigar a aplicabilidade de técnicas de privacidade diferencial a logs de infraestrutura, avaliando o equilíbrio entre proteção matemática garantida e utilidade analítica para fins de segurança da informação.

REFERÊNCIAS

Autoridade Nacional de Proteção de Dados (ANPD). *Guia de Boas Práticas – Anonimização e Pseudonimização*. Brasília, DF: [s.n.], 2022. ANPD. Disponível em: <<https://www.gov.br/anpd/pt-br>>. Acesso em: maio 2025. Citado 2 vezes nas páginas 20 e 25.

Autoridade Nacional de Proteção de Dados (ANPD). *Resolução CD/ANPD n° 19, de 2024 – Normas complementares sobre segurança e gestão de incidentes*. Brasília, DF: [s.n.], 2024. ANPD. Disponível em: <<https://www.gov.br/anpd/pt-br>>. Acesso em: maio 2025. Citado 3 vezes nas páginas 10, 19 e 38.

BRASIL. *Lei n° 12.965, de 23 de abril de 2014 – Marco Civil da Internet*. Brasília, DF: [s.n.], 2014. Presidência da República, Casa Civil. Disponível em: <https://www.planalto.gov.br/ccivil_03/_ato2011-2014/2014/lei/12965.htm>. Acesso em: maio 2025. Citado na página 20.

BRASIL. *Lei n° 13.709, de 14 de agosto de 2018 – Lei Geral de Proteção de Dados Pessoais (LGPD)*. Brasília, DF: [s.n.], 2018. Presidência da República, Casa Civil. Disponível em: <https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/13709.htm>. Acesso em: maio 2025. Citado 8 vezes nas páginas 10, 14, 17, 18, 21, 33, 37 e 38.

CICHONSKI, P. et al. *Computer Security Incident Handling Guide*. Gaithersburg, MD, 2012. Disponível em: <<https://doi.org/10.6028/NIST.SP.800-61r2>>. Acesso em: maio 2025. Citado na página 34.

DWORK, C.; ROTH, A. The algorithmic foundations of differential privacy. *Foundations and Trends in Theoretical Computer Science*, v. 9, n. 3–4, p. 211–407, 2014. Citado 2 vezes nas páginas 30 e 31.

European Parliament. *Regulation (EU) 2016/679 – General Data Protection Regulation (GDPR)*. 2016. Official Journal of the European Union. Disponível em: <<https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679>>. Acesso em: maio 2025. Citado 3 vezes nas páginas 10, 18 e 38.

KENT, K.; SOUPPAYA, M. *Guide to Computer Security Log Management*. Gaithersburg, MD, 2006. Disponível em: <<https://doi.org/10.6028/NIST.SP.800-92>>. Acesso em: maio 2025. Citado na página 13.

MICROSOFT. *Presidio – Data Protection and De-identification SDK*. 2023. GitHub. Disponível em: <<https://github.com/microsoft/presidio>>. Acesso em: maio 2025. Citado na página 24.

SOLOVE, D. J. *Nothing to Hide: The False Tradeoff between Privacy and Security*. New Haven: Yale University Press, 2011. ISBN 9780300177480. Citado na página 41.

SWEENEY, L. K-anonymity: a model for protecting privacy. *International Journal on Uncertainty, Fuzziness and Knowledge-based Systems*, v. 10, n. 5, p. 557–570, 2002. Citado na página 15.

ZUBOFF, S. *The Age of Surveillance Capitalism: The Fight for a Human Future at the New Frontier of Power*. New York: PublicAffairs, 2019. ISBN 9781610395694. Citado na página 40.

APÊNDICE A – CÓDIGO DEMONSTRATIVO DE ANONIMIZAÇÃO DE LOGS

Este apêndice reúne o código Python demonstrativo das técnicas de anonimização descritas no Capítulo 5, implementadas sobre logs MikroTik RouterOS com o framework Microsoft Presidio.

```

1  """
2  core_anonymizer.py
3  Demonstracao de anonimizacao LGPD para logs MikroTik.
4
5  Principios LGPD aplicados (Lei 13.709/2018):
6      Art. 6, III  -- Minimizacao: remove usernames
7      Art. 6, VII  -- Seguranca: hash SHA-256 nos IPs
8      Art. 6, VIII -- Prevencao: anonimizacao local
9      Art. 6, IX   -- Nao discriminacao: mascara MACs
10     Art. 46      -- Medidas tecnicas: pseudonimizacao
11
12     Autores: Cristian Siqueira, Daniel Hennig,
13             Marco Hendge, William Fagundes, Pedro Frosi
14 """
15
16 import re, hashlib, secrets, time
17 from dataclasses import dataclass, field
18 from typing import Literal
19
20 AnonymizationMode = Literal["hash", "mask", "redact", "replace"]
21
22 # --- Configuracao e resultado ---
23
24 @dataclass
25 class AnonymizerConfig:
26     ip_mode: AnonymizationMode = "hash"
27     mac_mode: AnonymizationMode = "mask"
28     redact_usernames: bool = True
29     hash_type: str = "sha256"
30     # Salt deve ser armazenado separadamente dos logs
31     salt: str = secrets.token_hex(32)
32
33 @dataclass
34 class ProcessingResult:
35     processed_lines: int = 0

```



```

36     ips_found: int = 0
37     macs_found: int = 0
38     usernames_found: int = 0
39     elapsed_seconds: float = 0.0
40     output_bytes: bytes = b""
41
42 # --- Padroes de deteccao ---
43
44 _IP_RE = re.compile(
45     r"\b(?:?:25[0-5]|2[0-4]\d|[01]?\d\d?)\.){3}"
46     r"(?:25[0-5]|2[0-4]\d|[01]?\d\d?)\b"
47 )
48 _MAC_RE = re.compile(
49     r"\b([0-9A-Fa-f]{2}:){5}([0-9A-Fa-f]{2})\b"
50 )
51 _USERNAME_PATTERNS = [
52     (re.compile(r"\buser\s+(\w+)\s+logged\b",
53         re.IGNORECASE), "user <USUARIO> logged"),
54     (re.compile(r"\bchanged\s+by\s+(\w+)\b",
55         re.IGNORECASE), "changed by <USUARIO>"),
56     (re.compile(r"\bfailed\s+login\s+attempt\s+for\s+(\w+)\b",
57         re.IGNORECASE),
58         "failed login attempt for <USUARIO>"),
59 ]
60
61 # --- Operadores de anonimizacao ---
62
63 def _op_ip(mode: str, salt: str, hash_type: str):
64     if mode == "hash":
65         def _hash(m):
66             dado = (salt + m.group()).encode()
67             return hashlib.new(hash_type, dado).hexdigest()
68         return _hash
69     if mode == "mask":
70         def _mask(m):
71             p = m.group().split(".")
72             return f"{p[0]}.***.***.*{p[-1][-1]}"
73         return _mask
74     if mode == "redact":
75         return lambda m: "<IP_REMOVIDO>"
76     return lambda m: "<IP_ANONIMIZADO>"
77

```

```

78 def _op_mac(mode: str, salt: str):
79     if mode == "hash":
80         def _hash(m):
81             dado = (salt + m.group()).encode()
82             return hashlib.sha256(dado).hexdigest()[:17]
83         return _hash
84     if mode == "mask":
85         def _mask(m):
86             tail = m.group()[9:]
87             return f"***:{tail}"
88         return _mask
89     if mode == "redact":
90         return lambda m: "<MAC_REMOVIDO>"
91     return lambda m: "<MAC_ANONIMIZADO>"
92
93 # --- Motor principal ---
94
95 class MikroTikAnonymizer:
96
97     def process(self, text: str,
98                 config: AnonymizerConfig = None) ->
99                 ProcessingResult:
100         if config is None:
101             config = AnonymizerConfig()
102
103         start = time.monotonic()
104         result = ProcessingResult()
105         ip_op = _op_ip(config.ip_mode,
106                        config.salt, config.hash_type)
107         mac_op = _op_mac(config.mac_mode, config.salt)
108         out = []
109
110         for line in text.splitlines():
111             # 1. Usernames (Art. 6, III - Minimizacao)
112             if config.redact_usernames:
113                 for pat, repl in _USERNAME_PATTERNS:
114                     line, n = pat.subn(repl, line)
115                     result.usernames_found += n
116
117             # 2. IPs (Art. 6, VII/VIII - Seguranca/Prevencao)
118             hits = _IP_RE.findall(line)
119             if hits:

```

```
119         result.ips_found += len(hits)
120         line = _IP_RE.sub(ip_op, line)
121
122         # 3. MACs (Art. 6, IX - Nao discriminacao)
123         hits = _MAC_RE.findall(line)
124         if hits:
125             result.macs_found += len(hits)
126             line = _MAC_RE.sub(mac_op, line)
127
128         out.append(line)
129         result.processed_lines += 1
130
131     result.elapsed_seconds = time.monotonic() - start
132     result.output_bytes = "\n".join(out).encode("utf-8")
133     return result
```

Listing A.1 – Pipeline de anonimizacao de logs MikroTik – core_anonymizer.py